

Maryam Rostamipoor

Senior Security Engineer (Systems & Application Security)

PhD '26 | San Jose, CA

Green Card Holder

GitHub: @mrostamipoor

mrostamipoor@cs.stonybrook.edu

LinkedIn: @maryam-rostamipoor

Website: mrostamipoor.github.io

Summary

Senior Security Engineer completing a **PhD in Computer Science** (May 2026), bringing six years of offensive-security industry experience across national-scale financial infrastructure plus five years of cloud-native security research. Built production-grade security systems evaluated across thousands of real-world applications, with **first-author publications at NDSS and IEEE EuroS&P**. Led application security programs — owning threat modeling, design reviews, penetration testing, and SDLC integration. Equally comfortable writing security tooling, reviewing code for vulnerabilities, hardening infrastructure, and communicating risk to engineering and executive audiences.

Core Areas: Application security, threat modeling, OWASP Top 10, secure code review, penetration testing (XSS, SQLi, SSRF, IDOR, RCE, authentication bypass), cloud security (AWS), Kubernetes and container security (seccomp, AppArmor), Linux kernel internals, secrets management, static and data-flow analysis, identity protocols (OAuth 2.0, OIDC, SAML, WebAuthn), CI/CD security integration, DevSecOps.

Experience

• Security Researcher — HexLab, Stony Brook University

Feb 2021 – May 2026

Cloud and Platform Security Research

Stony Brook, NY

- Developed **LeakChain**: developer-facing CI/CD security guardrail and IaC-aware static analysis framework (CodeQL) detecting sensitive data leakage across **intra-function, inter-function, and service-mediated** paths in **distributed** serverless deployments; detected **798** confirmed secret-exposure flows across **1,156** real-world applications with **100% precision / 93.2% recall**; integrated an **LLM-based AI security agent** to validate flows and reduce false positives.
- Built **KubeKeeper**: **secure-by-default** secrets management framework for Kubernetes applying **encryption with fine-grained decryption key access control** — only explicitly authorized Pods can retrieve keys, preventing unauthorized access regardless of RBAC misconfigurations; found **41%** of **498** real-world applications harbor exploitable excessive permissions, eliminating all identified exposures with **zero runtime overhead**. Published at **EuroS&P 2025**.
- Built **LeakLess**: in-memory encryption architecture protecting sensitive data against **memory-disclosure and transient-execution attacks** (Spectre/Meltdown class) in 91% of serverless applications with only **2.8–8.5%** overhead — by **confining all cryptographic operations to a trusted isolated process**, ensuring encryption keys never reside in the runtime's address space. Published at **NDSS 2025**.
- Created **Confine**: **automated container attack surface reduction** — generates restrictive seccomp policies via static binary analysis with **argument-level concretization**, filtering **144+** system calls on average and mitigating **28** Linux kernel CVEs, deployable as a security default without application-specific configuration. Published in *Computers & Security*, 2023.

• Sadad Electronic Payment Company

May 2018 – Feb 2021

Head of Software Security Team

Tehran, Iran

- Led **application security program** for a **national-scale banking ecosystem** — owning threat modeling, design reviews, and security architecture reviews across web, mobile, and API-driven financial systems, driving remediation of critical vulnerabilities.
- Developed **proof-of-concept exploits** for real-world vulnerabilities including **XSS, SQL injection, SSRF, IDOR, authentication bypass, and RCE**, demonstrating exploitability of critical attack chains in production financial applications.
- Conducted penetration testing of **20+ web/mobile services and APIs**, integrating **secure development practices** and developer-facing security tooling into the SDLC.
- Assessed security of **identity protocol implementations** (OAuth 2.0, OIDC, SAML) across banking applications, identifying token handling flaws, authentication bypasses, and misconfiguration vulnerabilities.
- Automated vulnerability triage and remediation tracking workflows, reducing remediation time by **40%**.

• APA Research Center, Amirkabir University of Technology

Feb 2017 – May 2018

Researcher & Senior Software Security Engineer

Tehran, Iran

- Conducted offensive security research and penetration testing across **90+** web, mobile, and API systems; discovered and demonstrated **CVSS ≥ 9** vulnerabilities via proof-of-concept exploits in national stock exchange infrastructure processing millions of daily transactions.
- Evaluated configurations against **CIS benchmarks**; designed secure baselines and automated auditing scripts for **54** production servers, reducing review time by **70%**. Guidance adopted by **100+** organizations.

• Stock Exchange Organization

Dec 2015 – Feb 2017

Senior Web Application Security Engineer

Tehran, Iran

- Led vulnerability research and offensive security assessments across **50+** production web applications and APIs; developed exploit demonstrations to validate and communicate risk to engineering teams.
- Hardened **54** production servers by designing secure baselines and automated auditing scripts, reducing configuration review time by **70%**.

• Bug Bounty & Vulnerability Disclosure (Independent)

Bug Bounty Researcher — [Kolahsefid.ir](https://kolahsefid.ir), [Cert.ir](https://cert.ir) disclosure platforms

Nov 2016 – Sep 2020

Iran

- Participated in **50+** bug bounty programs through coordinated disclosure platforms; responsibly disclosed multiple vulnerabilities rated **CVSS $\geq$ 9.0 (critical)**, driving remediation across host organizations.

Skills

- **Application & Web Security:** Threat modeling (STRIDE), OWASP Top 10, secure code review, proof-of-concept exploit development; XSS, SQLi, SSRF, IDOR, CSRF, deserialization, authentication bypass, RCE; Burp Suite, SQLmap, Metasploit, Nessus.
- **Cloud & Container Security:** AWS (IAM, VPC, S3, Lambda, Security Hub, IAM Access Analyzer), Kubernetes (RBAC, Secrets, Admission Webhooks), Docker, IaC security validation, CI/CD security (GitHub Actions), secrets management, secure-by-default architecture.
- **Systems & Program Analysis:** Linux kernel internals, system-call filtering (seccomp, AppArmor), container isolation, applied cryptography, in-memory encryption; static and dynamic analysis (CodeQL, angr, Ghidra), data- and taint-flow tracking.
- **Identity & Access Security:** OAuth 2.0, OIDC, SAML, SCIM, WebAuthn/FIDO2; identity protocol assessment (token handling flaws, authentication bypass, misconfiguration).
- **AI Security:** LLM-based agent development for security automation; LLM-assisted source/sink modeling and rule synthesis; prompt injection research.
- **Programming:** Python, C, Go, Rust, JavaScript.

Education

- **Ph.D. in Computer Science** 2021 – 2026
Stony Brook University, NY GPA: 3.91/4.0
Thesis: Detecting and Preventing Sensitive Data Leakage in Cloud-Native Environments
- **Master in Information Security Engineering** 2011 – 2013
Amirkabir University of Technology, Iran GPA: 17.73/20
- **Bachelor in Computer Engineering** 2007 – 2011
Shiraz University of Technology, Iran GPA: 16.64/20

Awards and Honors

- **Catacosinos Fellowship** for academic excellence and research potential 2025
- **Internet Society NDSS Fellowship** 2025
- Selected for the **CRA-WP Grad Cohort for Women & IDEALS** 2025
- **GAANN Fellowship** (U.S. Dept. of Education) 2023

Talks & Presentations

- **Invited Speaker**, University of Iowa CS Colloquium — *Rising Stars*, Iowa City, IA, March 2026. “*Preventing Sensitive Data Leakage in Modern Cloud-Native Platforms.*”
- **Conference Talk**, IEEE European Symposium on Security & Privacy (EuroS&P), Venice, Italy, July 2025. “*KubeKeeper: Protecting Kubernetes Secrets Against Excessive Permissions.*”
- **Conference Talk**, Network and Distributed System Security Symposium (NDSS), San Diego, CA, February 2025. “*LeakLess: Selective Data Protection against Memory Leakage Attacks for Serverless Environments.*”

Publications

- **Maryam Rostamipoor**, Seyedhamed Ghavamnia, and Michalis Polychronakis. “*LeakLess: Selective Data Protection against Memory Leakage Attacks for Serverless Environments.*” **Network and Distributed System Security Symposium (NDSS)**, 2025.
- **Maryam Rostamipoor**, Aliakbar Sadeghi, and Michalis Polychronakis. “*KubeKeeper: Protecting Kubernetes Secrets Against Excessive Permissions.*” **IEEE European Symposium on Security & Privacy (EuroS&P)**, 2025.
- **Maryam Rostamipoor**, Seyedhamed Ghavamnia, and Michalis Polychronakis. “*Confine: Fine-grained System Call Filtering for Container Attack Surface Reduction.*” *Computers & Security*, 2023.
- Aliakbar Sadeghi, Salman Niksefat, and **Maryam Rostamipoor**. “*Pure-Call Oriented Programming (PCOP): Chaining the Gadgets Using Call Instructions.*” *Journal of Computer Virology and Hacking Techniques*, 14(2), 2018.

Under Submission

- Aliakbar Sadeghi, **Maryam Rostamipoor**, Nick Nikiforakis, and Omar Chowdhury. “*Fake APIs, Real Threats: Studying Activities Targeting APIs in the Wild.*” Under submission.
- **Maryam Rostamipoor**, and Michalis Polychronakis. “*LeakChain: Detecting Sensitive Data Leakage Across Distributed Serverless Applications.*” Under submission.
- Aliakbar Sadeghi, **Maryam Rostamipoor**, Sai Chand Boyapati (Samsung Research America), and Omar Chowdhury. “*Breaking the Gate: Detecting Invisible Authentication Slip-Through in NGINX Reverse Proxy.*” Under submission.

Open-Source Artifacts

- github.com/mroostamipoor/KubeKeeper — Kubernetes Secrets protection framework (EuroS&P '25 artifact).
- github.com/mroostamipoor/LeakLess — in-memory encryption for serverless platforms (NDSS '25 artifact).